

FR-18: Quản lý Đơn hàng Admin - Hiển thị an toàn địa chỉ giao hàng - Domain Testing

1. Chức năng kiểm thử

Thuộc tính	Nội dung
Project	EShop
Feature	FR-18: Order management (admin) / FR-18: Quản lý Đơn hàng (Admin) - Hiển thị an toàn địa chỉ giao hàng
SUT	EShop - Web Admin và Backend API

2. Phân hoạch tương đương

2.1. Đầu vào và đầu ra

Loại	Tên	Mô tả
Đầu vào	Authorization token	Token admin dùng để mở danh sách đơn hàng có địa chỉ giao hàng.
Đầu vào	shipping_address	Dữ liệu địa chỉ giao hàng do user nhập trong checkout; có thể chứa chữ thường, ký tự đặc biệt, hoặc chuỗi giống HTML/script.
Đầu ra	Nội dung địa chỉ trên Web Admin	Địa chỉ được hiển thị như văn bản an toàn, không được render HTML hoặc thực thi JavaScript.
Đầu ra	Dữ liệu APIGET /api/admin/orders	API trả dữ liệu đơn hàng để Web Admin hiển thị; contract không nêu schema chi tiết nhưng cần có địa chỉ nếu màn hình quản lý hiển thị trường này.
Đầu ra	Phản hồi xác thực/phân quyền	User không đủ quyền không được truy cập dữ liệu địa chỉ trong danh sách admin.

2.2. Điều kiện

Mã	Đầu vào/Đầu ra	Điều kiện
C1	Authorization token	Request lấy danh sách đơn hàng admin phải có token hợp lệ.
C2	Authorization token	Token phải thuộc tài khoản córole = 'admin'.
C3	shipping_address	Địa chỉ văn bản thông thường phải hiển thị đúng nội dung người dùng đã nhập.
C4	shipping_address	Chuỗi chứa thẻ HTML phải được hiển thị an toàn như văn bản hoặc được escape, không được render thành phần tử HTML.
C5	shipping_address	Chuỗi chứa JavaScript/event handler phải không được thực thi.
C6	shipping_address	Ký tự đặc biệt như<, >, ", ', & phải không phá vỡ cấu trúc DOM hoặc layout quản lý đơn hàng.
C7	shipping_address	Trường rỗng/thiếu/null chưa có rule cụ thể; hệ thống phải hiển thị trạng thái an toàn, không crash và không render HTML.
C8	Nội dung địa chỉ trên Web Admin	Nội dung hiển thị không được dùng kết quả render HTML làm giao diện cuối cùng.
C9	Phản hồi xác thực/phân quyền	Thiếu quyền admin không được xem dữ liệu địa chỉ giao hàng của đơn hàng toàn hệ thống.

2.3. Lớp tương đương

EC	Đầu vào/Đầu ra	Lớp tương đương	Hợp lệ?	Giá trị đại diện	Kết quả mong đợi
EC01	Authorization token	Token hợp lệ của admin.	Có	Authorization: Bearer <valid_admin_token>	Cho phép xem dữ liệu địa chỉ trên Web Admin/API admin.
EC02	Authorization token	Thiếu token, token sai, hoặc token user thường.	Không	Không gửi token hoặc token củatest@eshop.com	Từ chối truy cập dữ liệu admin, bao gồm địa chỉ giao hàng.
EC03	shipping_address	Địa chỉ văn bản thông thường, không chứa markup.	Có	123 Le Loi, Q1, TP.HCM	Web hiển thị đúng nội dung địa chỉ như văn bản.
EC04	shipping_address	Địa chỉ chứa thẻ HTML cơ bản.	Có	123 Le Loi	Web hiển thị ký tự/thông tin địa chỉ an toàn; không tạo chữ đậm bằng thẻ hoặc node HTML ngoài ý muốn.
EC05	shipping_address	Địa chỉ chứa payload script hoặc event handler.	Có		Web không thực thi JavaScript, không bật alert, không tạo phần tử HTML nguy hiểm; nội dung được escape/hiển thị an toàn.
EC06	shipping_address	Địa chỉ chứa ký tự đặc biệt có ý nghĩa trong HTML.	Có	Apt "5" & <Gate A>	Web không vỡ DOM/layout; ký tự đặc biệt được hiển thị an toàn như dữ liệu text.
EC07	shipping_address	Địa chỉ rỗng/thiếu/null.	Có	"" hoặc null nếu có thể dựng qua dữ liệu kiểm thử	Web hiển thị trạng thái an toàn/fallback phù hợp theo SUT; không crash và không render HTML.
EC08	Nội dung địa chỉ trên Web Admin	Hệ thống render chuỗi HTML thành HTML thật hoặc thực thi script.	Không	Payload EC04/EC05 được render thành tag/alert	Không đạt FR-18/SEC-04 vì dữ liệu user nhập không được escape khi hiển thị.
EC09	Dữ liệu APIGET /api/admin/orders	API cung cấp địa chỉ dạng chuỗi để UI hiển thị.	Có	Item đơn hàng cóshipping_address quan sát được	API trả dữ liệu chuỗi; kiểm an toàn render thực hiện trên Web Admin.
EC10	Dữ liệu APIGET /api/admin/orders	API thiếu địa chỉ cho đơn cần hiển thị hoặc biến đổi mất dữ liệu không được đặc tả.	Không	Đơn đã checkout với địa chỉApt "5" & <Gate A> nhưng danh sách admin không có địa chỉ	Không đủ dữ liệu để kiểm/hiển thị địa chỉ giao hàng trong quản lý đơn hàng.

2.4. Ca kiểm thử EP

TC	Mục tiêu	Dữ liệu kiểm thử	Lớp được bao phủ	Kết quả mong đợi	Kết quả thực tế	Đạt
EP-FR18-	Hiển thị địa chỉ văn bản thông	Chuẩn bị đơn0_addr_plain qua	EC01, EC03,	Web: dòng đơn hiển thị địa chỉ123 Le	API trả itemid=1 với shipping_address="123 Le	Đạt

TC	Mục tiêu	Dữ liệu kiểm thử	Lớp được bao phủ	Kết quả mong đợi	Kết quả thực tế	Đạt
ADDR-001	thường.	checkout với <code>shipping_address="123 Le Loi, Q1, TP.HCM"</code> . Web: admin mở Quản lý Đơn hàng . API: admin gọi GET <code>/api/admin/orders</code> .	EC09	Loi, Q1, TP.HCM như văn bản. API: contract chưa nêu schema; nếu body có <code>shipping_address</code> , giá trị tương ứng là chuỗi đã nhập hoặc dữ liệu tương đương quan sát được.	Loi, Q1, TP.HCM . UI đưa giá trị vào cột địa chỉ.	
EP-FR18-ADDR-002	Không render thẻ HTML trong địa chỉ.	Chuẩn bị đơn <code>O_addr_html</code> với <code>shipping_address="123 Le Loi"</code> .	EC01, EC04, EC08, EC09	Web: không biến địa chỉ thành chữ đậm/tag HTML; nội dung được escape hoặc hiển thị an toàn như text. API: có thể trả chuỗi địa chỉ; API không kiểm chứng rendering nên dùng Web để kết luận.	API trả nguyên chuỗi <code>123 Le Loi</code> . UI Web Admin render địa chỉ bằng <code>`dangerouslySetInnerHTML={{ __html: o.shipping_address</code>	Đạt
EP-FR18-ADDR-003	Không thực thi JavaScript/event handler trong địa chỉ.	Chuẩn bị đơn <code>O_addr_script</code> với <code>shipping_address=""</code> .	EC01, EC05, EC08, EC09	Web: không xuất hiện alert/script execution, không tạo phần tử HTML nguy hiểm; địa chỉ được escape/hiển thị an toàn. API: body nếu có chỉ là dữ liệu chuỗi; không thể thay thế kiểm UI.	API trả nguyên payload <code></code> . Vì UI dùng <code>dangerouslySetInnerHTML</code> , payload có thể tạo thẻ <code>img</code> và event handler thay vì hiển thị như văn bản an toàn. UI source <code>App.jsx</code> .	Không
EP-FR18-ADDR-004	Hiển thị an toàn ký tự đặc biệt HTML.	Chuẩn bị đơn <code>O_addr_special</code> với <code>shipping_address="Apt \"5\" & <Gate A>"</code> .	EC01, EC06, EC09	Web: hiển thị đúng ý nghĩa văn bản, không vỡ DOM/layout; các ký tự <code><, >, ", &</code> không làm thay đổi cấu trúc HTML. API: dữ liệu chuỗi được ghi nhận để đối chiếu.	API trả đúng chuỗi <code>Apt "5" & <Gate A></code> . UI không escape mà đưa vào <code>innerHTML</code> , nên đoạn <code><Gate A></code> có nguy cơ bị trình duyệt phân tích như markup thay vì text. UI source <code>App.jsx</code> .	Không
EP-FR18-ADDR-005	Xử lý địa chỉ rỗng/thiếu an toàn.	Chuẩn bị hoặc quan sát đơn có <code>shipping_address=""</code> hoặc thiếu/null nếu luồng checkout/API cho phép.	EC01, EC07	Web: không crash, không render HTML, hiển thị trống hoặc fallback an toàn theo SUT. API: ghi nhận body thực tế vì contract chưa nêu rule cho địa chỉ rỗng.	API tạo được <code>O5</code> với <code>shipping_address=""</code> ; danh sách admin trả chuỗi rỗng. UI dùng fallback <code>"Chưa cập nhật"</code> , không crash.	Đạt

TC	Mục tiêu	Dữ liệu kiểm thử	Lớp được bao phủ	Kết quả mong đợi	Kết quả thực tế	Đạt
EP-FR18-ADDR-006	Từ chối user không đủ quyền xem địa chỉ trong admin orders.	GọiGET /api/admin/orders bằng token user thường hoặc không gửi token.	EC02, EC09	Web: không hiển thị màn hình/dữ liệu địa chỉ của quản lý đơn hàng admin. API: trả lỗi xác thực/phân quyền theo contract thực tế; không lộ địa chỉ giao hàng của đơn hàng toàn hệ thống.	Thiếu token trả401, nhưng token user thường gọi GET /api/admin/orders trả 200 thay vì lỗi phân quyền. Do backend không kiểm role, user thường có thể lấy dữ liệu địa chỉ nếu có token hợp lệ.	Không
EP-FR18-ADDR-007	Phát hiện API/danh sách admin thiếu địa chỉ cần hiển thị.	ĐơnO_addr_special đã checkout với địa chỉ quan sát được, admin gọi danh sách đơn hàng nhưng item không có trường/nội dung địa chỉ để Web hiển thị.	EC01, EC06, EC10	Web/API chỉ đạt nếu dữ liệu địa chỉ cần hiển thị có thể quan sát trong quản lý đơn hàng. Nếu dữ liệu mất hoặc bị biến đổi không được đặc tả, cần ghi nhận actual và review.	API admin orders có trườngshipping_address cho các đơn đã checkout và giữ nguyên giá trị đã nhập, gồm plain/html/script/special/empty.	Đạt

3. Phân tích giá trị biên

3.1. Xác định miền liên tục có thể phân tích biên

Đầu vào/Đầu ra	Dạng miền	Có áp dụng BVA?	Lý do
shipping_address	Chuỗi tự do	Không	Tài liệu không nêu độ dài tối thiểu/tối đa, regex, hoặc ngưỡng số ký tự; yêu cầu chính là escape/render an toàn, phù hợp EP theo loại nội dung.
Ký tự đặc biệt HTML	Tập ký tự/membership	Không	Đây là lớp ký tự đặc biệt chứ không phải miền có thứ tự với min/max được đặc tả.
Authorization token	Chuỗi/token	Không	Token chỉ có phân lớp hợp lệ/không hợp lệ/admin/user; không có boundary độ dài trong specification.
Số lượng payload script	Count	Không	Specification không nêu ngưỡng số lượng payload; chỉ cần mọi dữ liệu user nhập khi hiển thị đều được escape đúng cách.

3.2. Xác định biên và giá trị cận biên

Trường	Quy tắc biên	Giá Trị biên và cận biên
shipping_address	Không có biên độ dài hoặc ngưỡng được đặc tả	Không sinh giá trịmin-1/min/max+1; dùng EP với đại diện text thường, HTML tag, script/event handler, ký tự đặc biệt, và rỗng/thiếu.

3.3. Ca kiểm thử BVA

TC	Trường	Biên được kiểm thử	Dữ liệu kiểm thử	Kết quả mong đợi	Kết quả thực tế	Đạt
----	--------	--------------------	------------------	------------------	-----------------	-----

Không sinh ca BVA riêng cho file này vì shipping_address không có boundary được đặc tả. Các lớp rủi ro bảo mật được bao phủ bằng EP ở EP-FR18-ADDR-002 đến EP-FR18-ADDR-005.